

AI Cyber WatchDog R1

<https://github.com/TheShadoru/AI-Cyber-Watchdog>

An Open Source Adventure in AI
& Vulnerability Management





Players

Player 01.

Rich Wickersham

The watchdog use case
developer

Player 02.

Joe Carroll

The AI Developer

Player 03.

Ujval Bucha

The Software Engineer
and contributor

Player 04.

Tom Bendiem

The Open Source and
Private AI Guru



Agenda



The Use Case

The Vuln Management
Problem



The Stack

Private AI,
Pre-Trained Models,
obtainable hardware
and interesting
modules



The Demo

See the WatchDog in
Action!



Future Releases

Additional Modules,
Refinement and
Triggered Actions!

A pixel art landscape featuring a central white sign with a black border and a drop shadow. The sign contains the text 'The Problem!' in a black, monospaced font. The background consists of a bright blue sky with two white, pixelated clouds. Below the sky are two snow-capped mountains with blue-grey slopes. In the foreground, there is a green grassy field and a brown dirt ground. On the left, a brown stone tower with a red conical roof and a small orange flag stands next to a green tree. On the right, another brown stone tower with a crenelated top stands next to a smaller green tree.

The Problem!



Vulnerability Management Problems

Inaccurate CMDB

Can anyone that has worked in a large company say that **the CMDB is 100% accurate!**

TTE TTKE Decreasing

We need to **react faster** to keep up with the adversary space. AI is throwing gas on this fire!

High Volume of Vulns

The Volume of Critical or Known Exploitable Vulns has increased

Wrong Focus

Not focused on what matters most(**External Facing/Exploitable** , **Crown Jewels, Adversary**)



RECENT CISA KEV/Zero Day examples

Citrix warns of new Netscaler zero-days exploited

By Sergiu Gatlan



Citrix urged customers on Tuesday to immediately patch Netscaler ADCs online against two actively exploited zero-day vulnerabilities.

The two zero-days (tracked as CVE-2023-6548 and CVE-2023-6549) i

EMERGENCY DIRECTIVES

ED 24-01: Mitigate Ivanti Connect Secure and Ivanti Policy Secure Vulnerabilities

January 19, 2024

RELATED TOPICS: [CYBERSECURITY BEST PRACTICES](#)



Snowflake Warns: Targeted Credential Theft Campaign Hits Cloud Customers

Jun 04, 2024 Newsroom

Cloud Security / Data Protection



Cloud computing and analytics company Snowflake said a "limited number" of its customers have been singled out as part of a targeted campaign.

"We have not identified evidence suggesting this activity was caused by a vulnerability, misconfiguration, or breach of Snowflake's platform," the company said in a joint statement along with CrowdStrike and Google-owned Mandiant.

HEY, YOU! FRUSTRATED BY DISTRACTIONS THAT KNOCK TRACK AND MAKE YOU LOSE THE GREATEST RISKS WITH POTENTIAL FOR HIGH IMPACT BUSINESS? IT'S TIME TO ADDRESS CRITICAL RISKS AND GET READY. YOU CAN REPORT TO THE BOARD. FIX WHAT MATTERS.

XM Cyber



Continuous Attack Surface Penetration Testing

Continuously discover, prioritize, and remediate exposures with evidence-backed

— Trending News



Solutions and Objectives

The AI Cyber Watchdog Project will

- Provide actionable intelligence **quickly** for Known Exploitable Vulnerabilities
- Determine our exposure by validating exposure both **internally** and **externally**
- Utilize **RAG** to pull in data from multiple sources(CMDB, Shodan, Pastebin, Telegram, etc)
- CREATE Threat SUMMARY DATA and WRITE to a file for further document chat/analyst interrogation.

In a world where the adversary space is speeding up we need to be faster!



The stack= its simple , low cost and private !

Web UI

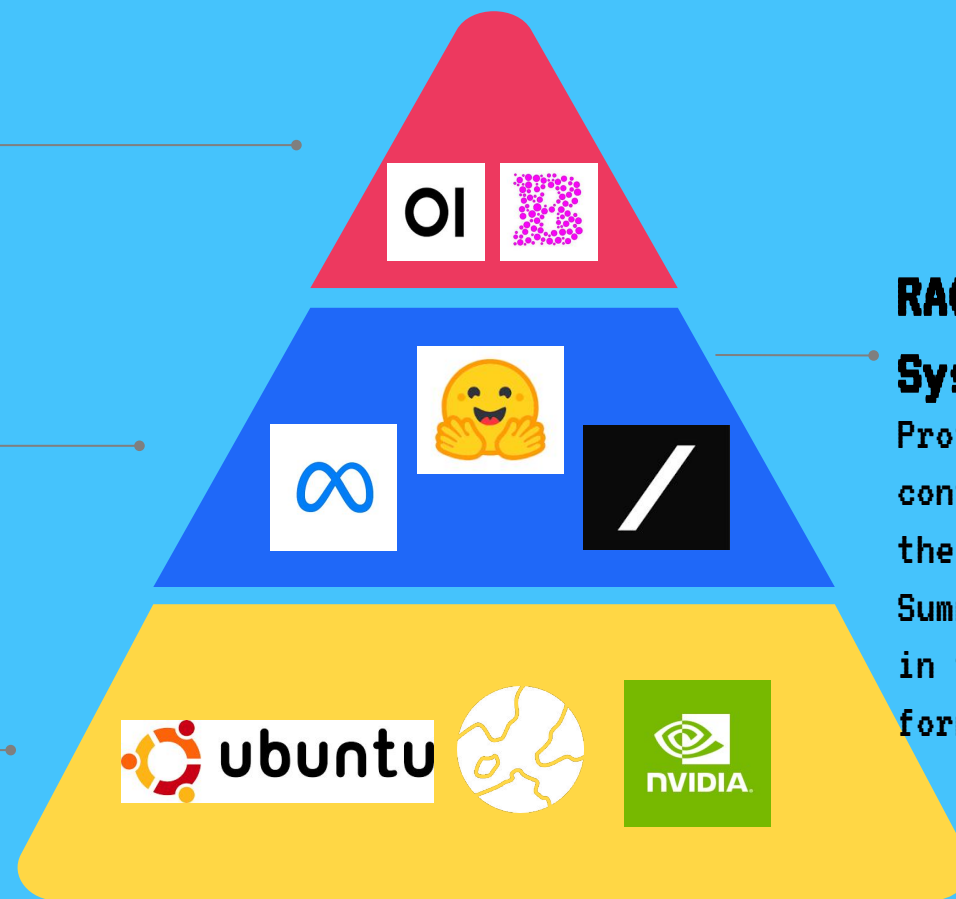
self hosted WebUI, API and control point. **Bionic** OR **Open WebUI** for document chat

Pre Trained Models

The CyberWatchDog is running today on **llama 3.1 70B**, or 8B from Fridays Labs. We will also use **Groq** for a hybrid demo.

Infrastructure

Built with low cost available GPUs and hardware, cloud hosted or **private stand-alone solutions**

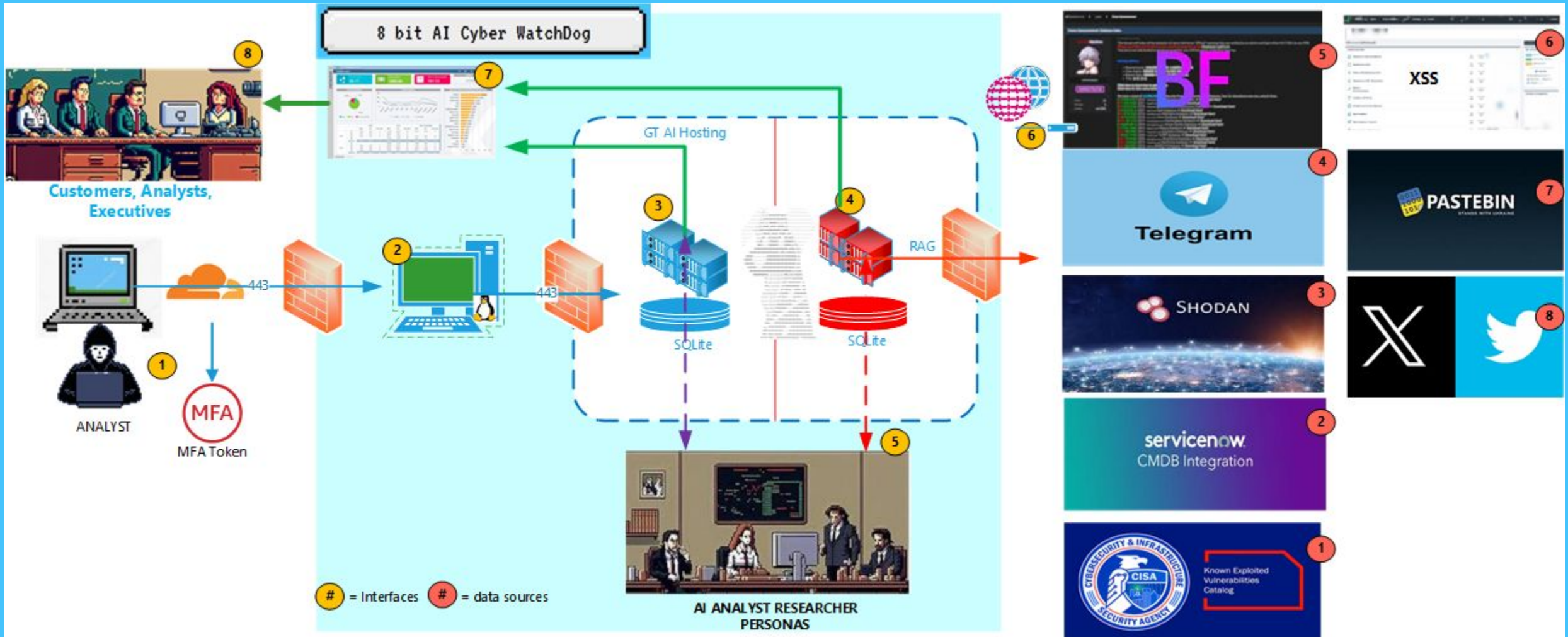


RAG +

System Prompts

Provide customer context. Pulls in the data we need. Summarizes output in the required format

The Solution



The AI Cyber WatchDog timeline



01. Use case Documented

Private AI infrastructure Stack
Created
CISA KEV + Shodan use case created

03.

Open Source project created

Config files created, dark web
use cases developed, system
prompts modified, output DB
created, updated config file

12/23

1/24-4/24

4/24-7/24

8/24-Current

00.

Start-up use case

We needed an idea beyond
Document Chat!

02.

Modules Added

CISA, Shodan, Pastebin
RAG APP modules created,
basic system prompts
created

04.

Modules added R1

Dark web modules created



The Modules

1. CISA KEV

A RAG App pulls data from the KEV RSS, summarizes and writes to local vector DB



3. CMDB Validation

This module is under construction, we used synthetic data for our demo



5. Pastebin

The Company name, vuln and keywords are used to find mentions



2. Shodan

The Company name and keywords from CISA KEV are used to find and summarize vulnerable **External Facing** infrastructure



4. Dark Web-Telegram

We will run through the telegram or leakbase module today! XSS, or Exploit.io



Reports & Document Chat

Summary reports are generated and analysts Document CHAT with the local vector DB



AI, RAG,
SYSTEM
Prompts

The new Modules = Dark Web

The “dark web” modules:

- ✔ Are used to determine if we have mentions of an active exploit in the wild on a specific forum{XSS, Exploit.io, Telegram}.
- ✔ Are used to identify an active exploit against the environments we are trying to protect!
- ✔ Are summarized and written to a file for further analyst document chat
- ✔ Current modules include LeakBase{.}io and Telegram

Customer Context

Intelligence sources are useful but they are not customer specific/lack parameters.

The Customer Context captures the unique customer requirements

1. Allow filtered approach to data collection via RAG
 - a. keywords matching
 - b. location based threats
 - c. Software assets
 - d. Specific threat actors
 - e. Matching customer network ranges



ALL OUT OF
BUBBLE GUM



DEMO TIME

Evaluation Pre and Post AI



3+ hours to assess the impact of a CVE(KEV) while relying on an inaccurate CMDB
1+ hour to prepare the deliverable(s)
1+ hour to orchestrate response
Broken\Slow Process REPEATS for all KEV CVE or critical misconfigurations



15 minutes to generate a virtual analyst assessment based on a source of truth for internet facing vulns!
15 minutes for analysis products
Zero day response is accelerated!

Prompt Engineering

```
config['SHODAN'] = {  
  
    '# provide an alternative ollama inference url if desired. (this will override the system wide ollama  
    url setting in the "global" section above.)\n'  
  
    'OLLAMA_URL': '<enter Ollama url here>',  
  
    '\n'  
  
    '# An API key is needed to utilize the Shodan module. You can get a Shodan API key here:  
    https://account.shodan.io/billing\n'  
  
    'API_KEY': '<enter Shodan API key here>',  
  
    '\n'  
  
    'PROMPT': 'Provide a summary of this report. Then, detail steps of mitigation in bullet format',  
  
    '\n'  
  
    '# Enter a valid Ollama LLM model name as needed. (This will override the system wide Ollama  
    LLM setting in the "global" section above.)\n'  
  
    'OLLAMA_LLM': 'llama3.1',  
  
    '\n'
```

PROMPT ENGINEERING:

Original Simple Prompt:

'PROMPT': 'Provide a summary of this report. Then, detail steps of mitigation in bullet format.',

Engineered Prompt:

'PROMPT': 'Provide a one paragraph summary of the report. Then, predict the attack vectors and prioritize the steps of mitigation in a list format using MITRE ATT&CK with references',

The background is a pixel art landscape. At the top, a bright blue sky contains two white, pixelated clouds. In the center, a large white rectangular sign with a black border and a slight drop shadow displays the text 'Thank you!' in a large, black, pixelated font. Below the sign, the URL 'https://github.com/TheShadoru/AI-Cyber-Watchdog' is written in a smaller, magenta, pixelated font. The bottom half of the image shows a green grassy field above a layer of brown soil. In the distance, there are blue mountains with white snow-capped peaks. On the left, a brown stone tower with a red conical roof and a small orange flag on top stands. On the right, another brown stone tower with a crenelated top is visible. Two green trees with pixelated foliage are positioned on either side of the central sign. In the lower center, a small, pixelated dog with brown fur, white spots, and floppy ears is standing on the grass.

Thank you!

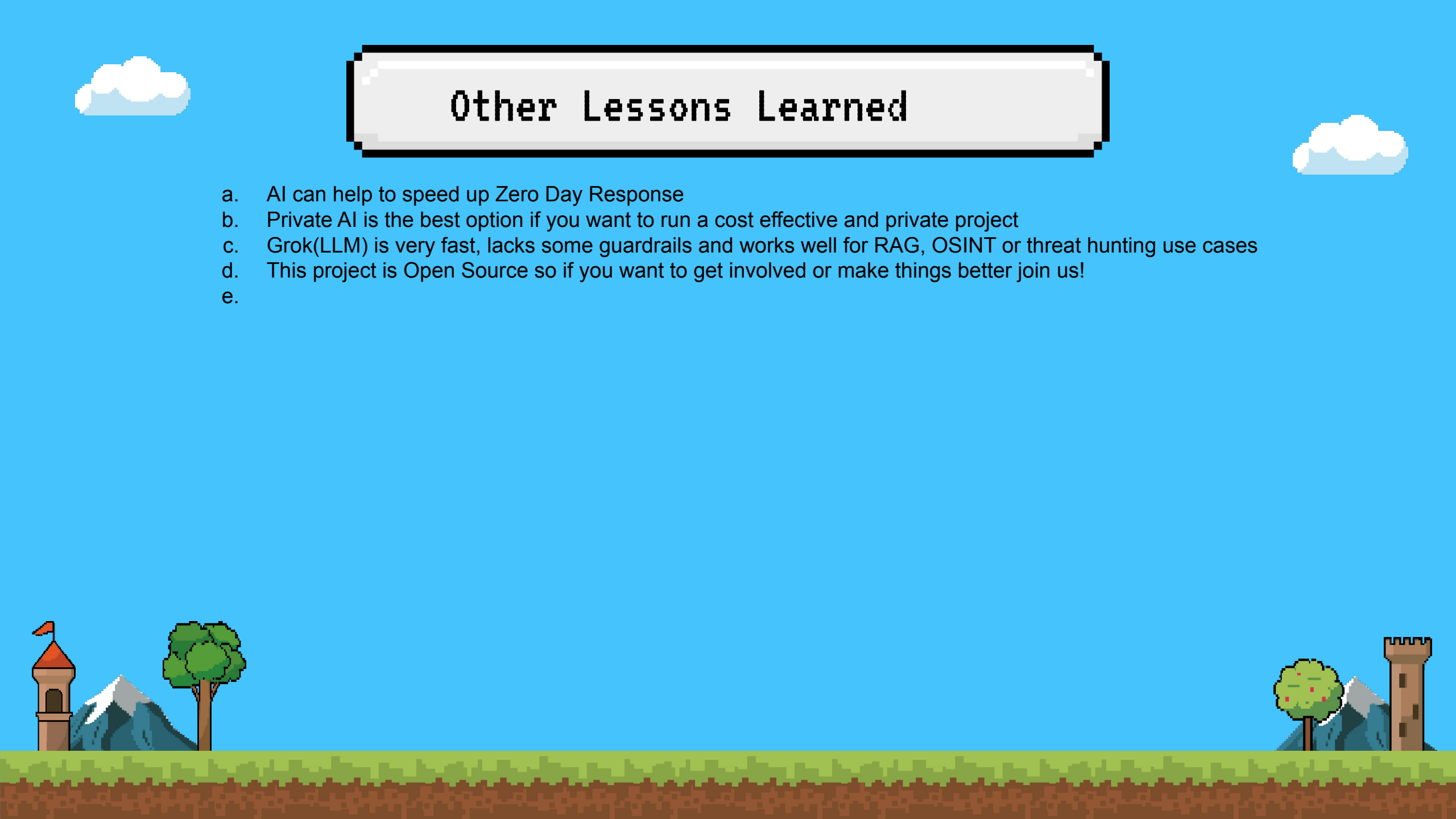
<https://github.com/TheShadoru/AI-Cyber-Watchdog>



Use Case Steps

1. Source KEV: A Known Exploitable Vulnerability is published (CISA RSS) to initiate the use case. This triggers the workflow for the purpose of this demo!
2. Source CMDB: Determine whether we have the vulnerable infrastructure in our environment(e.g. Cisco, Citrix, Ivanti)
Sources OSINT: The Analyst wants to search across OSINT sources(Shodan, Pastebin, etc)
Source Dark Web: The Analyst wants to search on cybercrime forums(company mentions, code, vuln)
3. Provide Customer Context: specific details(e.g. keywords) that are used to, prompt, retrieve and **summarize data**
4. Analysis: The Analyst wants a detailed report on inventory, patch level and likelihood of breach
5. Analysis: The analyst will ask the AI to **recommend remediation priority steps**, priority and deliver summary reports
 - a. MITRE ATT&CK and D3FEND can be used for the mapping
6. Retrieval Augmented Generation:
 - a. Connect to Multiple sources, deliver immediate answers and save/write pulled data for further document chat
 - b. Prompt engineering will: Retrieve all target relevant OR potentially vulnerable hosts/infra or software in our clients enterprise environment and validate externally via OSINT data and Dark Web data.
7. DB / Summary Reports:
 - a. **Each of the steps listed above writes to the DB(SQLite), allowing further document chat and will be transferred to Vector DB/DOC**





Other Lessons Learned

- a. AI can help to speed up Zero Day Response
- b. Private AI is the best option if you want to run a cost effective and private project
- c. Grok(LLM) is very fast, lacks some guardrails and works well for RAG, OSINT or threat hunting use cases
- d. This project is Open Source so if you want to get involved or make things better join us!
- e.

World map slide

